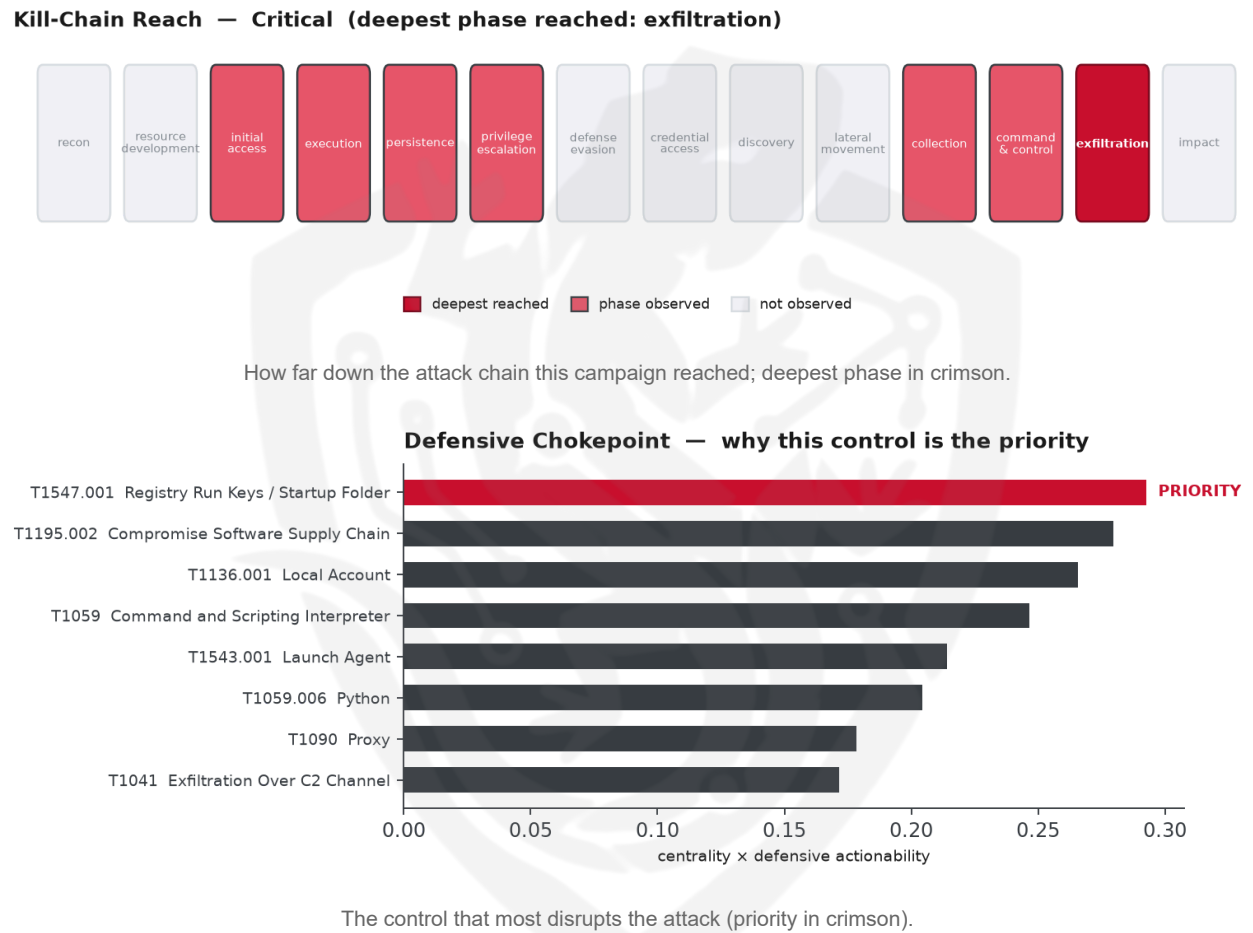


# THREAT REPORT: CROSS-PLATFORM RAT TARGETS ALIBABA DEVELOPERS VIA NPM PACKAGES

## Visual Summary



## Summary

The observed cluster of activity is delivering a cross-platform Remote Access Trojan (RAT) to target Alibaba developers, primarily in the technology sector. The malware families involved are lib-mtop and aone-cli, which exploit the CVE-2026-41940 vulnerability. Priority should be given to auditing Windows Startup folders and Run/RunOnce registry keys for unauthorized entries. The threat actor's identity is currently insufficient to determine, but their actions pose a critical operational risk due to the potential for exfiltration.

## Threat Overview

The threat actor, whose identity is currently unknown, is utilizing the lib-mtop and aone-cli malware families to target Alibaba developers. The central vulnerability being exploited is CVE-2026-41940,

allowing the actor to gain access to the targeted systems. The actor's techniques include screen capture, JavaScript execution, and data exfiltration over web services, among others.

## Attack Chain and Priority Control

---

The observed techniques form a chain that ultimately leads to the exfiltration of sensitive data. The priority technique is T1547.001 Registry Run Keys / Startup Folder, which serves as a chokepoint in the attack chain. To mitigate this threat, the priority control is to: Audit Windows Startup folders and Run/RunOnce registry keys for unauthorized entries; alert on .lnk or script creation in Startup by browser/email temp paths. In parallel, patch CVE-2026-41940 on all affected systems.

## Infrastructure and Corroboration

---

There is currently no available information on the hosting providers or ASNs observed in this campaign. Additionally, no malware families have been corroborated by abuse.ch, and AbuseIPDB has not flagged any indicators with a confidence level of 80% or higher.

## Technical Appendix

---

*Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.*

### Observed Techniques (ATT&CK, expert-tagged by source)

- T1113 Screen Capture
- T1059.007 JavaScript
- T1106 Native API
- T1005 Data from Local System
- T1140 Deobfuscate/Decode Files or Information
- T1567 Exfiltration Over Web Service
- T1136.001 Local Account
- T1090 Proxy
- T1059 Command and Scripting Interpreter
- T1041 Exfiltration Over C2 Channel
- T1547.001 Registry Run Keys / Startup Folder
- T1027 Obfuscated Files or Information
- T1195.002 Compromise Software Supply Chain
- T1059.006 Python
- T1543.001 Launch Agent
- T1070.004 File Deletion
- T1071.001 Web Protocols
- T1574.002 Hijack Execution Flow
- T1105 Ingress Tool Transfer

### Analytical Scores

- Priority technique (graph chokepoint): T1547.001 Registry Run Keys / Startup Folder (centrality 0.3082).
- Operational risk: Critical (score 0.968, reaches exfiltration).

## Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4243; reference threshold  $\tau = 0.6$ ).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

| Historical Profile | Behavioural Overlap |
|--------------------|---------------------|
| APT18              | 0.4243              |
| APT39              | 0.4007              |
| Higaisa            | 0.3748              |
| Rocke              | 0.3677              |
| BRONZE BUTLER      | 0.3677              |

## Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

## Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

| Type   | Indicator                                                                                  |
|--------|--------------------------------------------------------------------------------------------|
| Domain | diamond-cli-znsxphqell[.]cn-shanghai[.]fcapp[.]run                                         |
| URL    | hxxps://aone-cli-next[.]oss-cn-beijing[.]aliyuncs[.]com/config/setting[.]js                |
| URL    | hxxps://aone-ai-cli[.]oss-cn-beijing[.]aliyuncs[.]com/app/release/aone-cli[.]js            |
| URL    | hxxps://aone-ai-cli[.]oss-cn-beijing[.]aliyuncs[.]com/app/release/aone-cli-deps[.]tar[.]gz |
| URL    | hxxps://aone-ai-cli[.]oss-cn-beijing[.]aliyuncs[.]com/app/release/aone-cli                 |
| URL    | hxxps://aone-ai-cli[.]oss-cn-beijing[.]aliyuncs[.]com/app/release/aone-cli[.]zip           |
| URL    | hxxps://aone-kit[.]oss-cn-beijing[.]aliyuncs[.]com/plugins/crypto[.]js                     |

| Type | Indicator                                                                           |
|------|-------------------------------------------------------------------------------------|
| URL  | hxxps://aone-kit[.]joss-cn-beijing[.]aliyuncs[.]com/aone-kit-update/aone-kit[.]js   |
| URL  | hxxps://aone-kit[.]joss-cn-beijing[.]aliyuncs[.]com/aone-kit-update/app[.]asar      |
| URL  | hxxps://aone-kit[.]joss-cn-beijing[.]aliyuncs[.]com/aone-kit-update/aone-kit-update |
| Hash | 84a6ccaaab1596139d28e822f40cc99c68d337d4c81d1c6d9692c1d6bb22e4af                    |
| Hash | 6044974c633b3a319c31bb32110411520c425e89722a64806528553227e7a50a                    |
| Hash | 0910ecfa049738ef3f2540855341a380df89224ff71da94b4c21689fd66f62e3                    |
| Hash | b8b81af76163bdcc5b4f7d8fe6795f164991f8a62678c971db031b9e90a27813                    |
| Hash | ef9a1896eeaae929800eade768276e2240ef252d26d0d96c1950a1a5e1aadb34                    |
| Hash | e5d8350f1540fe91145dc262c455bca7748ad97dafb2d9facd5adebed9f66d2d                    |
| Hash | 41957bd0ba2d9c07af2e069f10780df6b2102c065bebe0db2136dfe07d67a28                     |
| Hash | 33b58598eb317553942e27545982d4c25ce6120eae10e42393746eb0e02ecae9                    |
| Hash | 3201d407b7899a12d6d439950511c6a5                                                    |

## Flame Cell // Adversary Pivot [ BETA ]

*BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? [norbert@salacti.com](mailto:norbert@salacti.com)*

- **Control applied:** T1547.001 Registry Run Keys / Startup Folder (persistence)
- **Observed here:** T1547.001 Registry Run Keys / Startup Folder was the only persistence technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1053 Scheduled Task/Job (persistence)
- **Basis:** of the 37+ groups that use Registry Run Keys / Startup Folder, this pairing runs 1.9x above base rate, a disproportionately-coupled move rather than the obvious one.

The actor could pivot to utilizing T1053 Scheduled Task/Job to maintain persistence and execute malicious code at a later time, potentially leveraging the Windows Task Scheduler to blend in with legitimate system activity, which may allow them to bypass defenses that are focused on immediate execution. This technique in particular could be appealing to the actor because it enables them to schedule tasks to run under the context of a specific user or system account, which may provide access to sensitive resources. To counter this potential move, the defensive control would be to alert on new scheduled tasks (Event ID 4698); restrict schtasks/at to admins; baseline legitimate task creators.

**Also plausible (same tactic):** T1098 Account Manipulation (n=12, lift 2.0), T1112 Modify Registry (n=17, lift 1.7)

#### **Detection and hardening for the pivot (T1053 Scheduled Task/Job)**

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
  - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
  - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
  - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\
- **Harden:**
  - Restrict schtasks/at to administrators; disable the legacy at.exe
  - Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File